EXPERIMENT 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

Bank Loan Application Form — Security and Governance Use Case

---

Submitted by

Mohid Ahmed F

Register Number: **241401057**

1. Aim

To plan and apply security features and governance and administration practices in the Bank Loan Application Form application built in Zoho Creator — covering sign-in security, user access, data permissions, safe scripting and integrations, controlled changes and auditing — so that applicant data is protected and the application is managed in an orderly way.

The application stores personal details such as the applicant's name, email, phone number and address, together with loan details such as the application and repayment dates, interest rate, reason for loan and supporting documents, so access control and accountability are essential.

2. Procedure

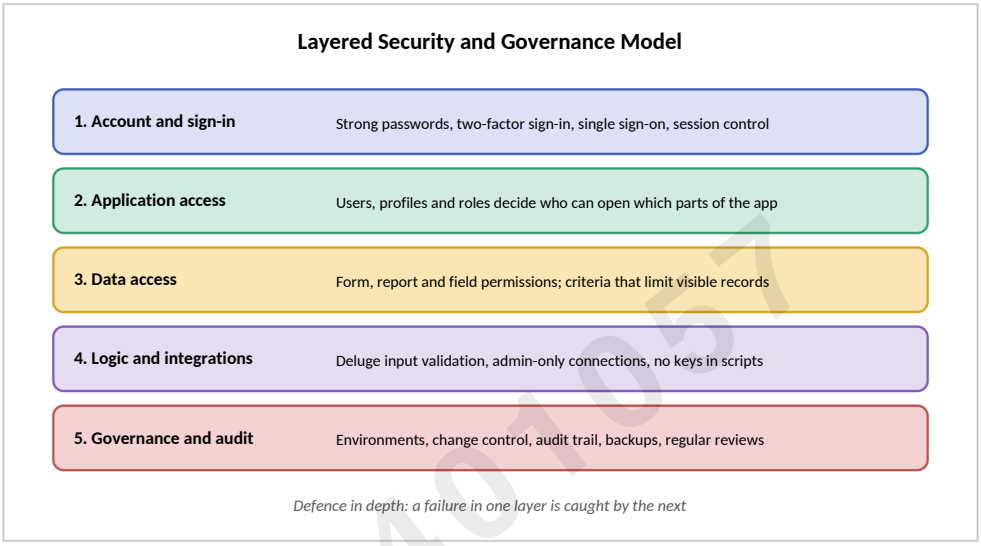
24140157

1. **Identify what needs protection** — The loan application form and its reports and dashboard were reviewed, and the sensitive data was listed: applicant identity, email, phone number, address, loan terms, uploaded documents and approval status.
2. **Plan account security** — Sign-in protection was planned for all users: strong passwords, two-factor sign-in and single sign-on where the organisation uses it (Section 3.1).
3. **Design roles and permissions** — Four user types — Loan officer, Applicant, Guarantor and Auditor, matching the roles created in Experiment 8 — were defined, and a permission matrix was prepared following the principle of least privilege (Section 3.2).
4. **Define the access flow** — The checks made when a user opens the application were drawn as a decision flow (Section 3.3).
5. **Secure scripts and connections** — Safe Deluge practices were drafted, such as validating input on the loan application form and keeping any external connection limited to administrators, in line with the workflow work in Experiment 10 (Section 3.4).
6. **Set up governance** — Controlled changes through development, stage and production environments, audit review and periodic access reviews were planned (Section 3.5).
7. **Prepare the admin checklist** — Threats and matching controls were tabulated, and an administration checklist was prepared for regular use (Sections 3.6 and 3.7).

Note: the settings are described as a planned configuration, except for the roles, permission sets and data-sharing rule that were actually set up in Experiment 8. No screenshots of the other settings were captured for this record, so it does not claim that every option was turned on. Feature names and availability depend on the Zoho Creator plan and version and should be confirmed in the current documentation.

3. Output

3.1 Layered security and governance model



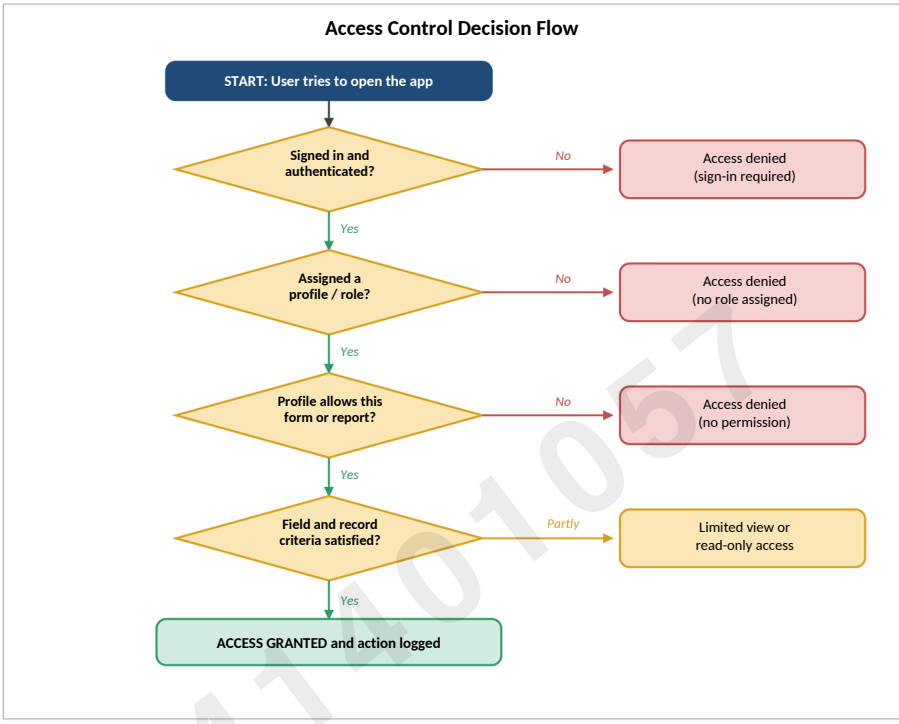
Security is arranged in five layers: account sign-in, application access, data access, logic and integrations, and governance with audit. A failure in one layer is caught by the next, which is the idea of defence in depth.

3.2 Proposed permission matrix

Each user type receives only the access needed for the job (least privilege). The matrix is a proposed design for the loan application system; the loan officer's Read/Write access to applicant records follows the data-sharing rule from Experiment 8, and users, roles, sharing rules and workflows are managed only by the application owner (CEO role).

Form / report	Loan officer	Applicant	Guarantor	Auditor
Loan applications (loan application form)	View, edit	Create and view own application	View linked application	View only
Applicant details (phone, address)	View, edit	Own entry only	No access	View only
Loan terms and documents (interest rate, documents)	View, edit	Enter own application	No access	View only
Approval status and reason	Update	View own status	No access	View only
Dashboard and Kanban views	View all	No access	No access	View all
Users, roles, sharing rules, workflows	No access	No access	No access	No access

3.3 Access control decision flow



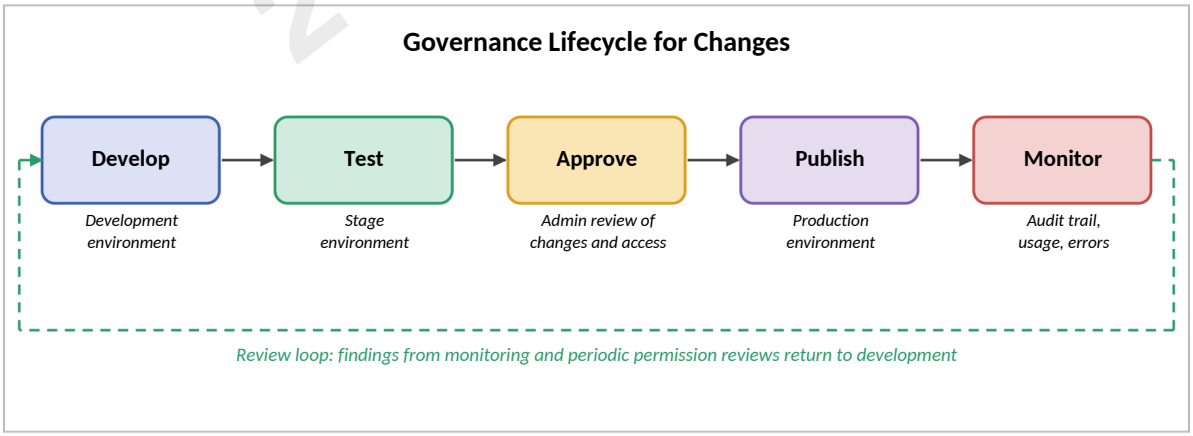
When a user tries to open the application, the system checks sign-in, then the assigned profile or role, then permission on the form or report, and finally field and record criteria. Failing any check denies or limits access, and granted actions are logged.

3.4 Secure scripting and connection practices (illustrative)

```
// On validate of the loan application form
if(input.Email.isBlank())
{
    alert "Email address is required to confirm the application.";
    cancel submit;
}
if(input.Application_date  >  input.Repayment_date)
{
    alert "Repayment date must be after the application date.";
    cancel submit;
}
if(input.interest_rate < 0 || input.interest_rate > 100)
{
    alert "Please enter an interest rate between 0 and 100.";
    cancel submit;
}
// Connection: use the stored link name, never a key written in the script
```

Input is validated on the server side of the form so wrong or missing data is rejected. Any credentials needed for an external service stay in a connection, which is set to administrators only, and values such as the interest-rate limit should be stored in a setting instead of being written inside the script. The field names and limits are assumptions for illustration, and the code is illustrative only.

3.5 Governance lifecycle for changes



Changes move from the development environment to the stage environment for testing, then to an administrator review, and only then to the production environment. Monitoring through the audit trail and periodic permission reviews feed improvements back into development.

24140157

3.6 Threats and matching controls

Threat	Example in this application	Control
Unauthorised access	A former employee opens applicant contact data.	Two-factor sign-in, prompt user removal, role-based access.
Excess privilege	An applicant can view or export all loan applications.	Least privilege, separate permissions for delete and export.
Data leakage	Reports, forms or uploaded documents shared publicly by mistake.	Review sharing settings; avoid public links.
Insecure scripts	Missing validation or keys inside Deluge code.	Validation on submit, connections instead of keys, code review.
Uncontrolled change	A live fix breaks loan application submission.	Dev, stage and production with approval.
No traceability	Nobody knows who approved or changed an application.	Audit trail review and periodic log checks.

3.7 Administration checklist

Area	Administration practice	How often
Users	Add users with the right role; remove leavers the same day.	On every change
Permissions	Review roles and the sharing rule against the matrix.	Every quarter
Sign-in	Confirm two-factor sign-in or single sign-on is enforced.	Every quarter
Connections	Check connections are administrator-only and needed.	Every quarter
Changes	Publish only after testing in the stage environment.	Every release
Audit	Look through the audit trail and usage metrics for unusual activity.	Monthly
Backup and recovery	Keep a recent backup and test that data can be restored.	As planned

2314010057

4. Final Result

A layered security and governance plan was prepared for the Bank Loan Application Form application, covering sign-in protection, role-based access with a least-privilege permission matrix, an access-control decision flow, secure scripting and connection practices, controlled changes through environments, and regular auditing. Threats such as unauthorised access, excess privilege, data leakage, insecure scripts, uncontrolled change and lack of traceability were matched with controls, and an administration checklist was drawn up for regular use.

The exercise met its objective of designing security and governance for the application. Apart from the roles and sharing rule configured in Experiment 8, the settings were not captured as screenshots, so the record presents them as a planned configuration to be confirmed in the live application.

24140157